

#1 - Security Policy

Security Rules and Guidelines

Rule 1: Privileges and Account Management

- Every user is given the minimum privileges necessary to perform their duties.
- Privileged accounts are monitored and require MFA.
- Accounts that are created should have documented justification, they should be reviewed every 90 days, and they should be immediately deactivated when no longer needed.

Rule 2: Secure Configurations and Patch Management

- All systems must run an approved base configuration that has secure settings, has disabled unnecessary services/programs, and has endpoint protection running.
- Critical security patches must be evaluated and applied within 14 days of them being released. Emergency patches for vulnerabilities that are being actively exploited must be applied within 48 hours.

Rule 3: Data Protection

- All data is classified into at least three tiers when it is created. For example, it could be: confidential, internal, public.
- Confidential data must be encrypted at all times using approved cryptography.
- Backups for critical data must be done daily and tested every month.

How This Security Policy Maintains the CIA Triad:

- **Confidentiality**
 - Privileges are able to limit who can access sensitive data.
 - Classification and encryption protects the data during storage and transfer.
 - **Integrity**
 - Having a baseline configuration reduces the risk of unauthorized modification.
 - Proper account management and documentation prevents unauthorized or accidental changes from happening.
 - **Availability**
 - Regular backups protect availability during incidents like hardware failure.
-

#2 - Incident Response Plan

Detection:

- The main detection method will consist of alerts based on correlation rules like unusual file encryption activity, mass file writes, sudden spike in CPU usage on a server.
- Additional detection methods will consist of endpoint detection and response, abnormal authentication alerts like failed logins, and user-reported phishing.

Containment:

- **Short-term containment:**
 - Isolate the affected hosts from the network by disabling their network interfaces or switching them into an isolated VLAN.
 - Block the known malicious IPs and domains at the firewall level.
 - Do not power off volatile evidence unless instructed.
- **Long-term containment:**
 - Apply temporary fixes like disabling compromised accounts and changing credentials.

Eradication:

- Identify and remove malware or other unauthorized access mechanisms by:
 1. Deleting malicious files after safely capturing evidence of the attack.
 2. Removing anything that might give persistence like scheduled tasks and startup entries.
 3. Patching exploited vulnerabilities and/or disabling any vulnerable services.

Recovery:

- Restore known-good backups where it's needed.
- Re-introduce systems that are no longer affected by the attack incrementally with increased monitoring and only after validated remediation.
- Re-verify the confidentiality, integrity, and availability of all systems.
- Notify people who are responsible for the Legal/Compliance side of Cybersecurity within 72 hours.

One Type of Cyber Attack Identified and Explained: Ransomware

- It is malware that encrypts and/or exfiltrates data and demands payment for decryption or non-disclosure.

- The typical indicators are sudden mass file encryption, unauthorized data extraction, and extortion demands.
-

#3 - Demonstrate Legal and Ethical Compliance

Two Relevant Laws/Regulations:

Law 1: General Data Protection Regulation (GDPR)

- Article 33 Requirement: “In the case of a personal data breach, the controller shall without undue delay and, where feasible, not later than 72 hours after having become aware of it, notify the personal data breach to the supervisory authority competent in accordance with Article 55, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. Where the notification to the supervisory authority is not made within 72 hours, it shall be accompanied by reasons for the delay.”
- How my plan ensures GDPR compliance: my plan enforces a 72-hour notification window to the Legal/Compliance team.

Law 2: Health Insurance Portability and Accountability Act (HIPAA)

- If the organization is a covered entity or business associate handling protected health information (PHI), then HIPAA applies. The relevant requirements are to include implementing administrative, physical, and technical safeguards under the HIPAA Security Rule and following the Breach Notification Rule for timely notification to affected individuals and HHS.
- How my plan ensures HIPAA compliance: my plan requires privilege access controls and it enforces logging and secure evidence preservation to support required investigations. It also talks about breach notification steps and uses contingency plans along with backups to support availability.

Ethical Consideration:

- Protecting user and customer privacy, and being transparent with any individuals affected by an attack.

How My Plan Upholds Legal Requirements and Ethical Principles:

- Evidence preservation and Notification procedures are documented to meet the regulatory requirements of the GDPR.
 - My plan includes requirements to re-verify the confidentiality, integrity, and availability of all systems. It also requires notifying the people affected and notifying the people on the Legal/Compliance side of Cybersecurity within 72 hours.
-

#4 - Apply Encryption Techniques

AES Encryption / Decryption Tool

AES Encryption

Encryption Text

Marcus

Secret Key

DAE1234567890123

Encryption Key Size

128 Bits

192 Bits

256 Bits

Encryption Mode

CBC

ECB

IV (optional)

IV

Output format

Base64

HEX

Encrypt

Encrypted Text

cHf/Js6lxKBZjU4heOnu9w==

AES Decryption

Encrypted Text

cHf/Js6lxKBZjU4heOnu9w==

Secret Key

DAE1234567890123

Encryption Key Size

128 Bits192 Bits256 Bits

Encryption Mode

CBCECB

IV (optional)

IV

Input format

Base64HEX

Decrypt

Decrypted Text

Marcus

MD5 Hash Generator

Use this generator to create an MD5 hash of a string:

Marcus

Generate →

Your String	Marcus	
MD5 Hash	a4e6a5ed8e8fbfe85b99eb74e29b04af	Copy
SHA1 Hash	323866ff0cf9b5c7f817d1d444274582bef7d324	Copy